

Project 2: Incident Response Lab Report

Incident ID: 2025-HSS-IR-002

Date: April 14, 2025

Status: Contained / Under Investigation

Classification: Major Security Incident

Executive Summary

Brief Description of the Organization and Its Critical Systems

HealthSecure Systems (HSS) is a regional provider of Electronic Health Record (EHR) software for small clinics and hospitals in the Midwest. HSS stores highly sensitive and regulated data, including personally identifiable information (PII), financial data, and payroll records for over 50 healthcare clients. Its critical systems include an HR SQL Server containing PII, a Development Server hosting proprietary source code, and a Finance network segment handling all client and employee payroll data.

Date/Time of Incident Discovery

The incident was discovered on **April 12, 2025, at approximately 01:24 AM EST**, when the HSS Snort-based Intrusion Detection System (IDS) generated three alerts for malicious activity originating from internal IP `192.168.1.45`.

What Was Impacted

- **Primary Asset:** Workstation-23 in the Finance Department was fully compromised. The attacker established a foothold and executed malicious code.
- **Data at Risk:** Sensitive Payroll and PII data, as the attacker accessed the HR SQL Server (`192.168.1.88`) via SMB and RDP connections.

- **Intellectual Property at Risk:** The Development App Server (192.168.1.200) in the DMZ was targeted in a lateral movement attempt, potentially to access proprietary healthcare source code.
- **Credentials:** Credentials for a former employee, jcampbell, were discovered in use and have been compromised.

Root Cause of the Incident

The incident was initiated by a successful **phishing attack** on a Finance department employee. The employee was lured by a spoofed email to download a malicious Excel file, which executed a PowerShell script to download a malicious payload from a command-and-control (C2) domain. A secondary, critical factor was the **failure of user offboarding procedures**, as the attacker utilized the still-active credentials of a former employee (jcampbell) to attempt to access the development environment.

Major Actions Taken

- **Immediate Isolation:** Workstation-23 was immediately isolated from the network.
- **Network Blocking:** Outbound connections to the malicious domains (maliciousdomain.xyz, secure-download.com) and IP (45.77.33.88) were blocked at the firewall.
- **Account Disablement:** The Active Directory account for former employee jcampbell was disabled.
- **Credential Reset:** Passwords for all active Finance and HR users and administrative service accounts were forcibly reset.
- **System Reimaging:** Workstation-23 is being re-imaged from a known, clean backup.

Key Recommendations to Improve Future Security Posture

1. **Automate User Offboarding:** Implement an automated identity and access management (IAM) solution to ensure instant deactivation of accounts upon employee termination, eliminating a critical vulnerability.

- 2. **Enhance Logging and Detection:** Immediately enable PowerShell logging across all endpoints, and deploy a centralized Security Information and Event Management (SIEM) system to enable real-time threat correlation and hunting.
- 3. **Strengthen Authentication:** Enforce Multi-Factor Authentication (MFA) for all remote access and all administrative accounts to mitigate the risk of credential theft and misuse.

1. Preparation

Roles, Responsibilities, and Tools

AREA	WHAT WAS IN PLACE	EVALUATION
Team	1 SOC Analyst, 1 Forensics Specialist, 1 IT Manager.	Lacking. No dedicated threat hunter, and the lean team is insufficient for a complex incident. The absence of a dedicated IR Lead or external partner was a hindrance.
Detection Tools	Snort (IDS), Zeek (Network Monitoring), Bitdefender (EDR).	Moderate. The IDS and network monitoring were effective in detecting and alerting on the incident. However, the lack of a centralized SIEM hindered efficient investigation and correlation.

Monitoring	Basic logging, but PowerShell logging was disabled on 30% of endpoints.	Critical Gap. This severely limited visibility into the attacker's actions and hindered the forensic analysis, as a key attack vector (PowerShell execution) was not fully captured.
IR Plan	An incident response playbook last updated in 2022.	Inadequate. The playbook is outdated and does not account for current attack techniques (e.g., cloud-based phishing, IoT threats).
Training	No recent phishing simulations or tabletop exercises.	Major Shortcoming. Employees are unprepared to identify sophisticated phishing attacks. The IR team has not practiced its response procedures, leading to potential delays and errors.
Offboarding	Manual offboarding process handled by HR and IT.	Critical Vulnerability. The incident was exacerbated by a manual process, leaving a former employee's account active and enabling lateral movement.

What is Missing or Insufficient

- **No SIEM:** The lack of a centralized SIEM to aggregate and correlate logs from different sources made the investigation manually intensive and slower.
- **Incomplete Logging:** PowerShell logging being disabled on 30% of endpoints is a severe blind spot, as this is a common attack vector.
- **Manual Offboarding:** A clear failure point that was directly exploited.

- **No Threat Hunting/Proactive Defense:** The organization is purely reactive, with no capability to proactively search for dormant or advanced threats.
- **Inadequate Training:** The absence of phishing simulations and tabletop exercises means both employees and the IR team are unprepared.

Actionable Suggestions to Improve Readiness

- **Deploy a SIEM:** Implement a SIEM (e.g., Splunk, Elastic Security, Azure Sentinel) to centralize log collection, enable real-time alerting, and facilitate threat hunting.
- **Enable PowerShell Logging:** Enforce a policy via Group Policy to enable script block logging and module logging for PowerShell on all Windows endpoints.
- **Automate Offboarding:** Procure and implement an IAM tool to automate the entire employee lifecycle, including de-provisioning, ensuring immediate account revocation and access termination.
- **Conduct Training:** Launch a quarterly phishing simulation program for all employees and conduct bi-annual tabletop exercises for the IR team.
- **Update the IR Plan:** Revise the Incident Response Playbook to include specific sections for ransomware, insider threats, and cloud-based attacks.

2. Detection and Identification

Indicators of Compromise (IoCs)

- **Malicious Domains:** `maliciousdomain.xyz`, `hss-payroll.secure-download.com`, `secure-download.com`.
- **Malicious IP Address:** `45.77.33.88` (C2 Server).
- **File Hashes (Expected):** Hash of `payload.ps1` (to be identified from the re-imaged workstation).
- **Registry/File Paths:** `C:\\*payload.ps1` (expected).
- **Network Signatures:** SMB connections to `192.168.1.88`, RDP connections to `192.168.1.88`, SSH attempts to `192.168.1.200` from `192.168.1.45`.
- **Process Activity:** `Invoke-WebRequest`, `powershell.exe`, `cmd.exe /c whoami`, `PsExecsvc.exe`.
- **Full URL:** <http://hss-payroll.secure-download.com/q1-update.xlsx>

- **Spoofed Sender** : HR-Payroll@healthsecuresystems.com
- **EDR Gap**: No alert on SSH attempt
- **Cached Credentials**: jcampbell in cached store

Log/Alert Analysis

1. **Phishing Email:** The incident began with a social engineering attack. A spoofed email from `HR-Payroll@healthsecuresystems.com` was sent to `accountant\_jane` in the Finance department. The email contained a link to a malicious domain (`hss-payroll.secure-download.com`), tricking the user into initiating the compromise.
2. **Initial Compromise & C2 Communication:** At `01:24:39`, Windows Event Log `4688` shows the execution of a PowerShell command to download a payload (`payload.ps1`) from `maliciousdomain.xyz`. This was further verified by the Snort outbound alert at `01:26:09`.
3. **Lateral Movement:** At `01:24:18`, Event `7045` logs the installation of the `PsExecsvc` service. This was followed by Zeek logging an SMB connection to HR-SQL01 (`192.168.1.88`) at `01:24:41` and an RDP session at `01:24:55`. This confirms the attacker's intent to move from the Finance workstation to the HR server to access sensitive data.
4. **Reconnaissance:** At `01:25:22`, the `cmd.exe /c whoami` command was executed, indicating the attacker was performing system discovery. At `01:25:30`, a DNS query for `secure-download.com` suggests further C2 communication or recon.
5. **Privilege Escalation Attempt:** The most concerning activity was the SSH login attempt to DevAppServer (`192.168.1.200`) at `02:11:34` using the credentials of `jcampbell`, a former developer. While unsuccessful, this demonstrates the attacker had obtained cached credentials and was actively seeking to escalate privileges to access intellectual property.

Incident Scope and Severity

AFFECTED AREA	STATUS	DETAILS
---------------	--------	---------

Finance Workstation-23	Confirmed Compromised	The initial infection vector. The attacker had full user-level access and established persistent mechanisms.
Development App Server (192.168.1.200)	Attempted Access	An unauthorized SSH login attempt was made using compromised credentials for a former employee.
HR SQL Server (192.168.1.88)	Attempted Access	The attacker established SMB and RDP connections, indicating a strong intent to access and potentially exfiltrate payroll and PII data.
User Accounts	Compromised	The account `finance_user` is compromised. Credentials for `jcampbell` (former employee) are compromised.

Severity Assessment: HIGH

The combination of successful initial compromise, lateral movement, attempted privilege escalation, and the presence of highly sensitive data (PII, payroll, intellectual property) categorizes this as a major security incident with potentially severe financial and reputational consequences for HSS.

3. Containment

Short-Term Actions (Immediate Mitigation)

ACTION	RATIONALE
Isolate Workstation-23	Prevent further C2 communication and lateral movement.
Block Outbound Traffic	Block network traffic to `45.77.33.88` and domains `maliciousdomain.xyz`, `secure-download.com`
Disable "jcampbell" Account	Immediately neutralize the compromised former employee credentials.
Reset Credentials	Force reset all Finance and HR user passwords and all service account credentials.
Enable Full Logging	Immediately enable PowerShell and other advanced logging on all critical systems.
Review Firewall Rules	Review and tighten any overly permissive internal firewall rules (e.g., RDP, SMB from non-administrative VLANs).

Long-Term Strategies (Prevent Recurrence)

STRATEGY	DESCRIPTION
Implement MFA	Enforce Multi-Factor Authentication for all remote access and all accounts with administrative privileges (VPN, Office 365, Domain Admin).
Network Segmentation	Strictly enforce segmentation between the Finance, HR, and Development networks. Implement a Zero-Trust architecture to limit east-west traffic.
Patch Management	Ensure all systems (especially Workstation-23, HR-SQL01, DevAppServer) are fully patched and up-to-date, including OS and critical applications.
Advanced Email Security	Deploy an email security solution with advanced phishing protection, sender authentication (SPF, DKIM, DMARC), and URL sandboxing.
EDR Policy Update	Create EDR watchlists and alerts for new threat patterns, such as the specific PowerShell commands used in this attack and the use of `PsExec`.

4. Eradication

Root Cause Analysis

The incident had two primary root causes:

1. **Human Error / Technical Lapse:** A Finance department user clicked on a malicious link in a sophisticated phishing email, allowing the initial payload to be executed.
2. **Process/Policy Failure:** The manual offboarding process failed to deactivate the account of a former employee (`jcampbell`). The attacker was able to

leverage these active credentials for lateral movement and privilege escalation attempts.

Why the Attack Succeeded

- **Insufficient Security Awareness:** The user was not adequately trained to identify and report the phishing attempt.
- **Inadequate Logging:** The disabled PowerShell logging on Workstation-23 hindered the investigation and made it difficult to fully understand the attacker's initial actions.
- **Lack of MFA:** The absence of MFA meant that a single set of credentials (those of `jcampbell`) was sufficient to attempt to access critical systems.
- **Poor Credential Hygiene:** The former employee's credentials were stored in a cached credential store on Workstation-23.

Eradication Steps

ACTION	DESCRIPTION
Malware Removal	Re-image Workstation-23 from a known, clean backup. All other potentially compromised systems will be scanned and cleaned or re-imaged.
System Patching	Ensure all discovered vulnerabilities on HR-SQL01 and DevAppServer are patched.
Credential Cleanup	Force a password reset on all accounts (Finance, HR, Admins). Conduct a comprehensive audit to ensure no other former employee accounts are active.

Malicious Files	Search for and delete any suspicious files (e.g., `payload.ps1`) on the network.
Network Rule Review	Conduct a full review of firewall and network access control lists (ACLs) to ensure they align with the principle of least privilege.

5. Recovery

Restoration Process

- **Workstation-23:** A clean, fully patched version of Windows 10 will be installed on a new or fully wiped hard drive. The user's data will be restored from a backup taken before the incident (if available and known to be clean). The system will be re-joined to the domain.
- **HR-SQL01:** After a full clean scan, database integrity checks will be run. A secondary, isolated restoration point will be created as a forensic backup for legal purposes.
- **DevAppServer:** SSH access logs and user directories will be scrutinized. The server will be scanned for vulnerabilities, and any flagged accounts will be audited.

Verification Steps

1. **Security Scans:** Run full anti-malware and vulnerability scans on all restored systems.
2. **Penetration Testing:** Conduct a focused penetration test from the Finance network to the HR and Development networks to validate that the offboarding fix and network segmentation are effective.
3. **Configuration Audit:** Check Group Policy and system configurations on the Domain Controller and other key servers to ensure logging is fully enabled.
4. **Log Integrity:** Compare logs from before and after the incident to ensure the response actions were effective.

Post-Recovery Monitoring

- **Enhanced Alerting:** Configure a SIEM (if deployed) or EDR with watchlists for the specific attack patterns observed (e.g., `Invoke-WebRequest` to malicious domains, `PsExec` installation).
- **Continuous Hunt:** Assign a threat hunting task to review the logs of all admin and former employee accounts for 90 days post-recovery.
- **Honeypot Expansion:** Enhance the honeypot on the DevAppServer to simulate more services and better entice attackers, providing earlier warnings.

6. Post-Incident Review

What Worked Well

- **Detection Tools:** The Snort IDS and Zeek network monitoring provided crucial, timely alerts that allowed the SOC team to identify the incident quickly.
- **Initial Response:** The SOC team acted promptly by isolating the affected system and blocking outbound traffic.
- **Honeypot:** The honeypot in the DMZ successfully alerted the team to the lateral movement attempt using `jcampbell`'s credentials, providing critical intelligence.

Areas for Improvement

- **Offboarding Process:** The manual offboarding process is a critical failure and the primary enabler for the attack's escalation.
- **Incomplete Logging:** The lack of PowerShell logging on many endpoints severely impaired the forensic investigation.
- **Outdated IR Plan:** The 2022 plan lacked specific procedures for modern threats like phishing-driven credential theft.
- **Lack of IR Training:** The team and organization were not prepared to identify or respond to a sophisticated phishing campaign.
- **Lack of Threat Intelligence:** No process was in place to block the known malicious domains or IP addresses before the attack.

Updated IR Plan Recommendations

1. **Revise Offboarding Procedures:** Immediately update the offboarding procedure to be automated and audited by a second party.
2. **Update Response Playbooks:** Add a new playbook specific to credential theft and lateral movement, using this incident's timeline as a case study.
3. **Logging Policy:** Update the organizational logging policy to mandate PowerShell and other critical logging on all endpoints.
4. **Introduce Threat Intelligence:** Establish a process for consuming free and paid threat intelligence feeds to proactively block known malicious domains and IPs at the firewall.

7. Continuous Improvement

Process Refinements

- **Quarterly Tabletop Exercises:** Conduct formal tabletop exercises bi-annually, simulating scenarios like phishing, ransomware, and insider threats.
- **Annual IR Plan Review:** Mandate an annual, formal review and update of the IR plan, incorporating lessons learned from exercises and industry best practices.
- **Automate Playbooks:** Use the SIEM to automate basic response actions (e.g., isolating an endpoint upon a high-confidence alert).

New Security Measures

- **SIEM Deployment:** Procure and deploy a SIEM for log aggregation, real-time correlation, and threat hunting.
- **Identity Management (IAM):** Implement an IAM solution to automate user lifecycle management, including automated offboarding and MFA enforcement.
- **Advanced Email Security:** Deploy a secure email gateway with AI-driven phishing detection and sandboxing of links and attachments.

Training Recommendations

- **Annual Security Awareness:** Mandatory, role-based training for all employees on identifying and reporting phishing and social engineering attacks.

- **Annual Phishing Simulations:** Run quarterly, realistic phishing simulation campaigns for all employees and report results to management.
- **IR Team Training:** Provide specialized training for the IR team on new threats, forensic techniques, and the use of the new SIEM and IAM tools.

8. Conclusion

The incident at HealthSecure Systems was a significant security breach stemming from a successful phishing attack and a critical failure in user offboarding. The attacker was able to compromise a Finance workstation, move laterally to sensitive HR systems, and attempt to access intellectual property using the credentials of a former employee.

The immediate incident has been contained through isolation, network blocking, and credential resets. However, the long-term security posture of HSS depends on addressing the systemic weaknesses uncovered during this investigation.

Key Recommendations:

1. **Automate the offboarding process** to immediately deactivate former employee accounts.
2. **Deploy a SIEM** and enable full logging across all systems to improve detection and response capabilities.
3. **Implement MFA** and advanced email security to prevent initial compromise and credential misuse.

By implementing these critical improvements, HSS can significantly reduce its risk profile, protect its sensitive data, and build a stronger, more resilient security posture for the future.